

# Konsep Mitigasi — SOAR

## Konsep Mitigasi Active Response — Malware vs Phishing

Bekal tanya-jawab sidang. Menjelaskan dua bentuk mitigasi aktif pada sistem SOAR ini: **karantina file (malware)** dan **sinkhole domain (phishing)** — apa konsepnya, apa yang sama, dan apa yang berbeda.

### 1. Sinkhole domain via /etc/hosts — konsep

**Sinkhole** = mengalihkan resolusi sebuah domain berbahaya ke alamat "buntu" agar tidak dapat dicapai. Pada sistem ini, Active Response `block-domain` menambahkan entri ke `/etc/hosts` pada endpoint:

```
0.0.0.0 phishing-jahat.com      # WAZUH-SOAR-SINKHOLE
0.0.0.0 www.phishing-jahat.com  # WAZUH-SOAR-SINKHOLE
```

`/etc/hosts` diperiksa **sebelum** DNS. Maka setiap upaya membuka domain tersebut dari endpoint akan diarahkan ke `0.0.0.0` (tidak ada server) sehingga **koneksi gagal total** (terbukti: `curl` → HTTP `000`).

**Efek:** memblokir **akses korban menuju situs phishing** (halaman pencuri kredensial / pengunduh payload) sebelum interaksi terjadi.

### 2. Karantina file — konsep

Active Response `quarantine-file` memindahkan file malware dari lokasi asal ke folder karantina lokal dan menguncinya:

```
mv ~/Downloads/malware.com → /var/ossec/quarantine/malware.com.<ts>.quarantined
chmod 000    (tak bisa dibaca / ditulis / dieksekusi)
```

**Efek:** menetralkan **artefak berbahaya yang sudah ada** di endpoint — file tidak hilang (masih ada untuk forensik) tetapi tidak bisa dijalankan/dibuka.

### 3. Perbandingan konsep

| Aspek                 | Malware — quarantine-file                                                       | Phishing — block-domain (sinkhole)                                  |
|-----------------------|---------------------------------------------------------------------------------|---------------------------------------------------------------------|
| Objek yang dimitigasi | Sebuah <b>file</b> yang sudah ada di endpoint                                   | Sebuah <b>domain / tujuan jaringan</b>                              |
| Lapisan               | Filesystem (pindah + <code>chmod 000</code> )                                   | Resolusi nama / jaringan ( <code>/etc/hosts</code> )                |
| Tahap kill-chain      | Ancaman <b>sudah masuk</b> → jinakkan artefaknya                                | <b>Cegah korban menjangkau</b> sumber jahat                         |
| Mekanisme             | <code>mv</code> ke <code>/var/ossec/quarantine/</code> + kunci <code>000</code> | Tambah entri <code>0.0.0.0 domain</code>                            |
| Cakupan efek          | 1 file spesifik                                                                 | Seluruh domain (+ <code>www</code> ) pada host tersebut             |
| Rollback              | <code>chmod</code> + <code>mv</code> balik (manual)                             | Hapus baris <code>/etc/hosts</code> (perintah <code>delete</code> ) |
| Sifat                 | Reversible, non-destruktif (file disimpan)                                      | Reversible, idempotent (ada backup <code>/etc/hosts</code> )        |

### 4. Yang SAMA (kenapa terasa mirip)

Keduanya memakai **pola SOAR yang identik**:

1. **Deteksi** (Wazuh) → 2. **Pengayaan** (VirusTotal untuk malware; Google Safe Browsing + URLScan.io untuk phishing) → 3. **Keputusan berjenjang** (auto bila keyakinan tinggi / tombol bila ambigu) → 4. **Active Response lokal di agent** → 5. **Notifikasi Telegram**.

Persamaan lain:

- Dieksekusi **di endpoint** (AR `location=local`), bukan di manager.
- **Reversible** (bisa di-rollback).
- Bisa dipicu **otomatis** atau lewat **tombol Telegram** (human-in-the-loop).

## 5. Analogi singkat

- **Karantina (malware)**: menyita & mengunci barang berbahaya yang **sudah terlanjur masuk** rumah.
  - **Sinkhole (phishing)**: **menutup jalan/alamat** menuju tempat berbahaya, agar penghuni tidak bisa ke sana.
- 

## 6. Antisipasi pertanyaan penguji

"Apakah sinkhole ini berlaku untuk seluruh jaringan?" Tidak — sinkhole ini **berbasis host** (`/etc/hosts`), jadi hanya melindungi endpoint tempat Active Response berjalan. Ini pilihan desain: ringan, tanpa infrastruktur DNS tambahan, dan cocok untuk endpoint mobile yang berpindah jaringan (via Tailscale).

"Kenapa tidak network-wide?" Mitigasi skala jaringan idealnya di **DNS server (Response Policy Zone / RPZ)** atau **firewall**. Itu dapat menjadi **pengembangan lanjutan**. Kelebihan pendekatan host saat ini: langsung berlaku di titik korban, tanpa perangkat jaringan tambahan.

"Kenapa file tidak langsung dihapus?" Sengaja disimpan (mode `000`) untuk **forensik/analisis lanjut** dan menghindari kehilangan data bila ternyata false positive. Restore dilakukan manual demi keamanan.

"Apa bedanya dengan sekadar blok IP?" Sinkhole domain memblokir **nama** (lebih tepat sasaran untuk phishing yang sering berganti IP / pakai CDN), sedangkan blok IP berisiko memblokir layanan sah yang berbagi IP. Karena itu untuk phishing dipilih sinkhole domain.